

Justificaciones de exclusiones STRIDE

Modelo de amenazas – Plataforma de e-commerce CompraFácil S.A.S.

Bootcamp Ciberseguridad – Módulo 2
Submódulo: Estrategias de arquitectura de seguridad

Mayo de 2026

1. Introducción general

El presente documento justifica, para cada elemento identificado en los **Diagramas de Flujo de Datos (DFD)** del workshop “*Estrategias de arquitectura de seguridad*” de la plataforma de e-commerce **CompraFácil S.A.S.**, las razones por las cuales **no se consideraron** algunas categorías de la metodología **STRIDE** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).

Las exclusiones se fundamentan en dos criterios principales:

1. **STRIDE-per-Element:** No todos los tipos de elementos del DFD son susceptibles a las seis categorías. Los almacenes de datos típicamente no aplican *Spoofing* ni *Elevation of Privilege* de manera directa, y las entidades externas solo aplican *Spoofing* y *Repudio*.
2. **Supuestos arquitectónicos (S1–S10):** Definidos en el enunciado del workshop, ciertos controles preexistentes o decisiones de diseño hacen que algunos riesgos se traten en otro componente del sistema, evitando duplicidad analítica.

Recordatorio de supuestos del workshop

- **S1.** Todo el tráfico externo debe usar HTTPS.
- **S2.** Los microservicios usan tokens JWT para autenticación.
- **S3.** El frontend no es confiable.
- **S4.** El usuario autenticado no necesariamente está autorizado para todos los recursos.
- **S5.** El proveedor de pagos envía webhooks de confirmación.
- **S6.** Las bases de datos no están expuestas directamente a Internet.
- **S7.** Existen roles de cliente y administrador.
- **S8.** Los servicios internos generan logs de seguridad.
- **S9.** Los secretos deben estar fuera del código fuente.
- **S10.** Los pagos se validan del lado servidor.

2. Flujo 1 – Autenticación de usuarios

2.1 Contexto

El Flujo 1 corresponde al *registro e inicio de sesión* de los usuarios en la plataforma. Es el flujo crítico de identidad: emite y verifica las credenciales (JWT) que el resto del sistema consume.

2.2 Resumen de cobertura STRIDE – Flujo 1

Componente	S	T	R	I	D	E
Frontend público (Proceso)	✓	✓	×	✓	✓	✓
API Gateway (Proceso)	×	✓	×	✓	✓	×
Microservicio de autenticación (Proc.)	✓	×	×	✓	✓	×
Gestión de secretos (Almacén)	×	×	×	✓	✓	×
DB Usuarios (Almacén)	×	✓	×	✓	×	×
Panel administrativo (Proceso)	×	×	✓	✓	✓	✓
Sistema de logs / SIEM (Almacén)	×	×	×	✓	✓	✓

2.3 Justificación por componente

2.3.1 Frontend público (Proceso) – excluido: R

- El frontend es un cliente delgado que solo renderiza y reenvía; no es fuente autoritativa de evidencias.
- Conforme al supuesto **S3**, no es confiable; la evidencia de no repudio se genera y conserva en el backend y en el SIEM (**S8**).
- Las acciones que requieren no repudio (compras, pagos, cambios administrativos) se ejecutan tras pasar por el API Gateway y se auditan aguas abajo.

2.3.2 API Gateway (Proceso) – excluidos: S, R, E

- **Spoofing (S)**: La autenticación se delega al microservicio de autenticación. El Gateway solo *valida* JWT (**S2**); la suplantación se modela en quien emite y verifica identidades.
- **Repudio (R)**: La evidencia se externaliza al SIEM (**S8**). No tendría sentido duplicar el control en cada salto.
- **Elevación de privilegios (E)**: El Gateway opera como router/proxy sin roles propios. Los privilegios se evalúan en los microservicios destino con base en los claims del JWT (**S4**, **S7**).

2.3.3 Microservicio de autenticación (Proceso) – excluidos: T, R, E

- **Tampering (T)**: Datos críticos (hashes, JWT) se generan y firman internamente, con secretos aislados (**S9**) y comunicación bajo HTTPS (**S1**). No hay puntos intermedios sin proteger.
- **Repudio (R)**: Eventos reportados al SIEM (**S8**); el control se materializa en el destino.
- **Elevación de privilegios (E)**: El servicio es el *emisor* de privilegios, no consumidor. La escalación se controla en los servicios que reciben el token.

2.3.4 Gestión de secretos (Almacén) – excluidos: S, T, R, E

- **S** y **E**: STRIDE-per-Element no aplica a almacenes.
- **Tampering (T)**: Secretos inmutables desde el consumidor; rotación administrada por el vault (**S9**); solo lectura.

- **Repudio (R):** Auditoría delegada al SIEM (S8).

2.3.5 DB Usuarios (Almacén) – excluidos: S, R, D, E

- **S y E:** No aplican a almacenes (STRIDE-per-Element).
- **Repudio (R):** Auditoría centralizada en SIEM (S8).
- **Denegación de servicio (D):** Aislamiento perimetral (S6); el DoS se modela en el microservicio consumidor.

2.3.6 Panel administrativo (Proceso) – excluidos: S, T

- **Spoofing (S):** Autenticación delegada al microservicio de autenticación con MFA (S2, S7).
- **Tampering (T):** El panel es solo cliente; las modificaciones reales se ejecutan y validan en los microservicios backend (refuerzo del supuesto S3).

2.3.7 Sistema de logs / SIEM (Almacén) – excluidos: S, T, R

- **S:** No aplica a almacenes.
- **Tampering (T):** Append-only con firmas/hashing nativos del SIEM.
- **Repudio (R):** El SIEM *es* el control de no repudio: aplicar la categoría sobre sí mismo sería recursivo.

3. Flujo 2 – Consulta de catálogo

3.1 Contexto

El Flujo 2 corresponde a la *consulta pública del catálogo de productos*: un cliente, autenticado o no, navega la tienda para ver inventario, precios y descripciones. Tres rasgos lo condicionan:

1. **Acceso anónimo y público:** no requiere autenticación obligatoria.
2. **Operación de solo lectura:** no modifica datos persistentes; las escrituras vienen del flujo administrativo.
3. **Sensibilidad media-baja:** los datos son comerciales y públicos.

3.2 Resumen de cobertura STRIDE – Flujo 2

Elemento	S	T	R	I	D	E
Cliente (Actor / Entidad externa)	×	×	×	×	×	×
Consulta de catálogo (Proceso de neg.)	×	×	×	×	×	×
Frontend público (Proceso)	✓	✓	×	✓	✓	✓
API Gateway (Proceso)	×	✓	×	✓	✓	×
Microservicio de productos (Proceso)	×	×	×	✓	✓	×
DB Productos (Almacén)	×	✓	×	×	×	×
Gestión de secretos (Almacén)	×	×	×	✓	✓	×
Sistema de logs / SIEM (Almacén)	×	×	×	✓	✓	✓

3.3 Justificación por elemento

3.3.1 Cliente (Actor / Entidad externa) – excluidos: todos

- Por STRIDE-per-Element solo aplicarían **S** y **R**.
- **S**: la consulta es anónima por diseño; suplantación se modela en el Flujo 1.
- **R**: la consulta no genera transacciones jurídicamente vinculantes que el cliente pueda negar.

3.3.2 Consulta de catálogo (Proceso de negocio) – excluidos: todos

- Es una abstracción lógica, no un componente técnico instanciado.
- Las amenazas se materializan en los componentes técnicos que la implementan; modelarlas aquí duplicaría el análisis.

3.3.3 Frontend público (Proceso) – excluido: **R**

- Cliente delgado no confiable (**S3**); auditoría delegada al SIEM (**S8**).
- Ver el catálogo no produce efectos transaccionales que requieran no repudio.

3.3.4 API Gateway (Proceso) – excluidos: **S**, **R**, **E**

- **S**: la consulta es pública; cuando hay JWT, su validación se delega al microservicio de autenticación (**S2**).
- **R**: evidencia centralizada en SIEM (**S8**).
- **E**: router/proxy sin lógica de negocio; en consulta no hay privilegio diferenciado que escalar.

3.3.5 Microservicio de productos (Proceso) – excluidos: **S**, **T**, **R**, **E**

- **S**: el servicio no autentica al usuario final en lectura pública.
- **T**: expone únicamente operaciones de lectura; las escrituras viven en el flujo administrativo.
- **R**: eventos hacia el SIEM (**S8**).

- **E**: endpoints públicos uniformes, sin diferenciación de roles.

3.3.6 DB Productos (Almacén) – excluidos: **S**, **R**, **I**, **D**, **E**

- **S**, **E**: no aplican a almacenes (STRIDE-per-Element).
- **R**: auditoría centralizada en SIEM (**S8**).
- **I**: el catálogo es *público por definición*; revelar nombres, precios o stock no es pérdida de confidencialidad.
- **D**: DB aislada (**S6**); el DoS funcional se modela en el microservicio consumidor.

3.3.7 Gestión de secretos (Almacén) – excluidos: **S**, **T**, **R**, **E**

- **S**, **E**: no aplican a almacenes.
- **T**: secretos inmutables, rotación controlada (**S9**).
- **R**: accesos auditados por el SIEM (**S8**).

3.3.8 Sistema de logs / SIEM (Almacén) – excluidos: **S**, **T**, **R**

- **S**: no aplica a almacenes.
- **T**: append-only con firmas/hashing nativos.
- **R**: es el propio control de no repudio; aplicarlo sobre sí mismo es circular.

4. Flujo 3 – Órdenes de compra

4.1 Contexto

El Flujo 3 corresponde a la *creación de órdenes de compra*: el cliente confirma su carrito, el sistema calcula totales, valida disponibilidad, persiste la orden y dispara el respaldo. A diferencia del catálogo, este flujo:

1. Es **transaccional** (datos financieros y compromisos comerciales).
2. **Requiere autenticación** del cliente para operar sobre sus propias órdenes (**S4**, **S7**).
3. Es **escritura persistente**, lo que vuelve críticas la integridad y la trazabilidad.

4.2 Resumen de cobertura STRIDE – Flujo 3

Elemento	S	T	R	I	D	E
Cliente (Actor / Entidad externa)	×	×	×	×	×	×
Creación de órdenes (Proceso de negocio)	×	×	×	×	×	×
Frontend público (Proceso)	✓	✓	×	✓	✓	✓
API Gateway (Proceso)	×	✓	×	✓	✓	×
Microservicio de órdenes de compra (Proceso)	×	✓	×	✓	×	×
Gestión de secretos (Almacén)	×	×	×	✓	✓	×
DB Órdenes de compra (Almacén)	×	✓	×	✓	×	×
Backups protegidos (Almacén)	×	×	×	✓	✓	×
Sistema de logs / SIEM (Almacén)	×	×	×	✓	✓	✓

4.3 Justificación por elemento

4.3.1 Cliente (Actor / Entidad externa) – excluidos: todos

- Por STRIDE-per-Element solo aplicarían **S** y **R**.
- **S**: la suplantación de identidad del cliente se modela en el Flujo 1 (Autenticación), que es donde se emiten y validan las credenciales.
- **R**: la prueba de la transacción se delega al microservicio de órdenes (firma del registro de venta) y al SIEM (**S8**); el cliente como entidad externa no es objeto de auditoría interna.

4.3.2 Creación de órdenes de compra (Proceso de negocio) – excluidos: todos

- Es una abstracción lógica del proceso transaccional, no una pieza técnica.
- Sus amenazas se materializan en los componentes que la implementan (Frontend, Gateway, microservicio, DB, backups, SIEM). Modelarlas aquí duplicaría el análisis y desplazaría el riesgo del nivel donde puede mitigarse.

4.3.3 Frontend público (Proceso) – excluido: **R**

- Cliente delgado no confiable (**S3**); cualquier confirmación de compra mostrada en pantalla es una representación visual, no la evidencia legal de la transacción.
- La firma y registro de la orden se hace en el microservicio, y el SIEM almacena la traza inmutable (**S8**). El no repudio se centraliza aguas abajo.

4.3.4 API Gateway (Proceso) – excluidos: **S**, **R**, **E**

- **S**: valida el JWT pero no autentica credenciales; la suplantación de cliente se controla en el microservicio de autenticación (**S2**).
- **R**: la evidencia transaccional vive en el SIEM y en la propia DB de órdenes (**S8**); el Gateway solo enruta.

- **E**: sin lógica de negocio ni roles propios; la autorización fina se evalúa en el microservicio destino (**S4**, **S7**).

4.3.5 Microservicio de órdenes de compra (Proceso) – excluidos: **S**, **R**, **D**, **E**

- **S**: no autentica al usuario final; consume el JWT validado por el Gateway/autenticación (**S2**).
- **R**: los eventos de creación/aprobación de órdenes se reportan al SIEM (**S8**); además, la propia DB de órdenes funciona como registro autoritativo. El control se materializa en los almacenes y en el SIEM, no dentro del servicio.
- **D**: la mitigación de saturación se aplica perimetralmente en el API Gateway (rate limiting, mitigación DDoS); el microservicio se beneficia indirectamente sin necesidad de modelar la amenaza por separado.
- **E**: la autorización por roles (cliente vs. administrador) se evalúa con los claims del JWT (**S4**, **S7**); no se exponen endpoints administrativos en este flujo.

4.3.6 Gestión de secretos (Almacén) – excluidos: **S**, **T**, **R**, **E**

- **S**, **E**: no aplican a almacenes (STRIDE-per-Element).
- **T**: secretos inmutables desde el consumidor; rotación bajo proceso del vault (**S9**); microservicios con permiso de solo lectura.
- **R**: auditoría de accesos exportada al SIEM (**S8**).

4.3.7 DB Órdenes de compra (Almacén) – excluidos: **S**, **R**, **D**, **E**

- **S**, **E**: no aplican a almacenes.
- **R**: auditoría centralizada en el SIEM (**S8**); además, la DB es la fuente autoritativa de la transacción.
- **D**: aislada de Internet (**S6**), accesible solo desde el microservicio de órdenes. El DoS funcional se modela en los componentes upstream (Gateway y microservicio).

4.3.8 Backups protegidos (Almacén) – excluidos: **S**, **T**, **R**, **E**

- **S**, **E**: no aplican a almacenes (STRIDE-per-Element).
- **T**: se trata de un repositorio *immutable* (WORM): la alteración de copias se evita por configuración nativa del almacén. La amenaza relevante remanente se reclasifica como *disponibilidad* (borrado/cifrado por ransomware), que sí se modela como **D**.
- **R**: auditoría delegada al SIEM (**S8**); los backups no operan como fuente de evidencia transaccional sino como copia de respaldo.

4.3.9 Sistema de logs / SIEM (Almacén) – excluidos: **S**, **T**, **R**

- **S**: no aplica a almacenes.
- **T**: append-only con firmas/hashing nativos del SIEM.
- **R**: el SIEM es el control de no repudio del flujo; aplicarle la categoría a sí mismo es circular.

5. Flujo 4 – Portal transaccional de pagos

5.1 Contexto

El Flujo 4 corresponde al *procesamiento de pagos en línea* mediante una pasarela bancaria externa. La conciliación se dispara cuando el cliente confirma el cobro (o cuando llega un *webhook* del proveedor) y termina actualizando el estado de la orden (Aprobado, Rechazado, Pendiente). Es el flujo con las características más críticas:

1. Involucra una **entidad externa de confianza acotada** (el proveedor de pagos), que cruza un *trust boundary*.
2. Maneja **datos financieros** (identificadores transaccionales, estado de cobro) y la **integridad del monto** es no negociable.
3. La comunicación con el proveedor se hace por *mTLS* y *webhooks* firmados (supuestos **S5** y **S10**).

5.2 Resumen de cobertura STRIDE – Flujo 4

Elemento	S	T	R	I	D	E
Proveedor de pagos (Entidad externa)	×	×	×	×	×	×
Conciliación de pagos (Proceso de negocio)	×	×	×	×	×	×
API Gateway (Proceso)	×	✓	×	✓	✓	×
Microservicio de pago (Proceso)	✓	✓	×	×	×	×
Gestión de secretos (Almacén)	×	×	×	✓	✓	×
DB Órdenes de compra (Almacén)	×	✓	×	✓	×	×
Sistema de logs / SIEM (Almacén)	×	×	×	✓	✓	✓

5.3 Justificación por elemento

5.3.1 Proveedor de pagos (Entidad externa) – excluidos: todos

- El proveedor de pagos está *fuera del perímetro de control* de CompraFácil; modelar amenazas sobre su infraestructura excede el alcance del workshop.
- Por STRIDE-per-Element solo aplicarían **S** y **R**:
 - **S**: la suplantación del proveedor (alguien que se hace pasar por él para enviar confirmaciones falsas) sí es una amenaza relevante, pero *se materializa en el microservicio de pago* (que valida certificados mTLS y firmas de webhook) y en el API Gateway (IP whitelisting). Por eso aparece marcada en el microservicio, no en el actor externo.
 - **R**: la trazabilidad del proveedor se garantiza mediante los registros firmados que él mismo emite y que CompraFácil almacena en el SIEM (**S8**); la auditoría no se modela “dentro” del actor.

5.3.2 Conciliación y procesamiento de pagos (Proceso de negocio) – excluidos: todos

- Es la abstracción lógica del proceso transaccional financiero, no un componente técnico instanciado.

- Sus amenazas se materializan en los componentes técnicos que la implementan (API Gateway, microservicio de pago, vault, DB de órdenes, SIEM). Modelarlas al nivel abstracto duplicaría el análisis.

5.3.3 API Gateway (Proceso) – excluidos: S, R, E

- **S**: la autenticación contra el proveedor (mTLS) se ejecuta en el microservicio de pago, no en el Gateway. Para el cliente interno, el Gateway sigue dependiendo del JWT validado por el microservicio de autenticación (**S2**).
- **R**: la evidencia se centraliza en el SIEM y en los registros transaccionales de la DB de órdenes (**S8**). El Gateway funciona como punto de paso para el webhook; los controles que se le piden son de integridad (firma) y disponibilidad (IP whitelisting), no de no repudio.
- **E**: el Gateway no tiene roles ni lógica de autorización; el control de privilegios se evalúa en los microservicios destino.

5.3.4 Microservicio de pago (Proceso) – excluidos: R, I, D, E

- **R**: las trazas de cada intento de cobro, las respuestas del proveedor y los cambios de estado se reportan al SIEM (**S8**); además, la DB de órdenes registra el estado final como evidencia autoritativa de la transacción. El no repudio se materializa en los almacenes.
- **I**: CompraFácil sigue un esquema de *tokenización*: no se almacenan PAN, CVV ni datos sensibles de tarjeta. La información que viaja por el microservicio se reduce a identificadores opacos y montos, cifrados en tránsito por mTLS (**S1**). Cualquier filtración accidental hacia logs se controla en el SIEM (donde sí se modela **I**). Por eso la confidencialidad no es una amenaza propia del microservicio.
- **D**: la mitigación perimetral (rate limiting, IP whitelisting) se aplica en el API Gateway. Adicionalmente, el proveedor de pagos opera con cuotas propias, lo que limita el vector de DoS dirigido al microservicio.
- **E**: el microservicio expone un único conjunto de operaciones de pago para usuarios autenticados; no maneja roles diferenciados ni endpoints administrativos en este flujo (la gestión administrativa de cobros vive en el Flujo 5).

5.3.5 Gestión de secretos (Almacén) – excluidos: S, T, R, E

- **S, E**: no aplican a almacenes (STRIDE-per-Element).
- **T**: las llaves privadas y credenciales mTLS son inmutables desde el consumidor; la rotación se realiza mediante un proceso administrado del vault (**S9**). El microservicio solo tiene permiso de lectura.
- **R**: la auditoría de accesos al vault se exporta al SIEM (**S8**), centralizando el no repudio fuera del almacén.

5.3.6 DB Órdenes de compra (Almacén) – excluidos: S, R, D, E

- **S, E**: no aplican a almacenes.
- **R**: la auditoría se centraliza en el SIEM (**S8**); la DB actúa además como registro autoritativo del estado del pago.
- **D**: aislada de Internet (**S6**) y solo accesible desde el microservicio de pago; la disponibilidad se gestiona perimetralmente en los componentes upstream.

5.3.7 Sistema de logs / SIEM (Almacén) – excluidos: S, T, R

- **S**: no aplica a almacenes.
- **T**: append-only con firmas/hashing nativos del SIEM; la inmutabilidad es propiedad del producto.
- **R**: el SIEM es el propio control de no repudio del flujo transaccional; aplicarlo sobre sí mismo es circular.

6. Flujo 5 – Gestión y operación administrativa

6.1 Contexto

El Flujo 5 corresponde a la *gestión administrativa* de la plataforma: un administrador interno (Admin) usa el panel administrativo para crear/modificar productos, gestionar usuarios, consultar órdenes y supervisar operaciones. El diagrama del workshop reduce este flujo a tres elementos visibles — Admin, Panel administrativo y SIEM — porque las operaciones efectivas sobre los datos las ejecutan los microservicios y bases ya modeladas en los flujos anteriores; lo que esta vista quiere resaltar es *el alcance del acceso administrativo* y su trazabilidad.

6.2 Resumen de cobertura STRIDE – Flujo 5

Elemento	S	T	R	I	D	E
Admin (Actor / Entidad externa)	×	×	×	×	×	×
Panel administrativo (Proceso)	×	×	✓	✓	✓	✓
Sistema de logs / SIEM (Almacén)	×	×	×	✓	✓	✓

6.3 Justificación por elemento

6.3.1 Admin (Entidad externa) – excluidos: todos

- Por STRIDE-per-Element, sobre una entidad externa solo aplicarían **S** y **R**:
 - **S**: la suplantación del administrador se modela en el Flujo 1 (Autenticación) y se refuerza con MFA, JWT con rol de admin y SSO corporativo (**S2**, **S7**). En el Flujo 5 el control ya está aplicado por upstream.
 - **R**: la prueba de las acciones administrativas se materializa en el SIEM (**S8**), no “dentro” del actor. Por eso **R** aparece en el Panel administrativo (origen del evento) y en el SIEM (destino), pero no en el Admin.

6.3.2 Panel administrativo (Proceso) – excluidos: S, T

- **Spoofing (S)**: la autenticación del administrador se delega íntegramente al microservicio de autenticación con MFA y SSO corporativo (**S2**, **S7**). Modelar la suplantación dentro del panel duplicaría el control.
- **Tampering (T)**: el panel actúa únicamente como *interfaz cliente*; cualquier cambio real (precios, inventario, usuarios) se ejecuta en los microservicios backend, donde se aplican validaciones de integridad (recomputación, sentencias parametrizadas, validación de esquema). Por aplicación del supuesto **S3** (“el frontend no es confiable”), las eventuales manipulaciones del lado del cliente no son la amenaza relevante: se invalidan en el servidor.

- **Lo que sí se considera (R, I, D, E):** aquí sí se modelan porque el panel es el punto donde puede ocurrir la *negación de una acción administrativa* (R), la *filtración de datos sensibles en vistas privilegiadas* (I), la *indisponibilidad operativa* (D) y, sobre todo, la *escalación de privilegios entre roles administrativos* (E), que es la amenaza más característica del flujo.

6.3.3 Sistema de logs / SIEM (Almacén) – excluidos: S, T, R

- **S:** no aplica a almacenes (STRIDE-per-Element).
- **T:** append-only con firmas/hashting nativos del SIEM; la integridad de los registros administrativos es una propiedad del producto.
- **R:** el SIEM es el control de no repudio del flujo administrativo (es donde se prueba que “el admin X hizo la acción Y a la hora Z”); aplicarle la categoría a sí mismo sería recursivo.
- **Lo que sí se considera (I, D, E):** la consola del SIEM contiene información sensible para auditoría, puede ser saturada y, sobre todo, puede ser manipulada por roles administrativos del SIEM con privilegios excesivos (de ahí que **E** sí se modele en este almacén, atípicamente, porque el SIEM expone una *consola administrativa propia* con roles internos).

7. Flujo 6 – Respaldo y llaves de seguridad

7.1 Contexto

El Flujo 6 es una *vista transversal* que muestra cómo los distintos microservicios consumen la bóveda de secretos para obtener credenciales y cómo las bases de datos relevantes se respaldan en el almacén de backups. No es un flujo funcional para el usuario final: es un flujo *operacional/transversal* cuyo objetivo es garantizar la **continuidad**, la **custodia de secretos** y la **recuperabilidad** ante incidentes.

Por su naturaleza, en este flujo la mayoría de los componentes ya fueron modelados a profundidad en los Flujos 1–4. La vista del diagrama *recorta* cada componente para resaltar solo las categorías STRIDE materialmente relevantes *para la operación de respaldo y consumo de secretos*: integridad (**T**), confidencialidad (**I**) y disponibilidad (**D**), más una marca de **S** en los servicios que se autentican contra el vault o contra terceros.

7.2 Resumen de cobertura STRIDE – Flujo 6

Elemento	S	T	R	I	D	E
Gestión de secretos (Almacén)	×	×	×	✓	✓	×
Microservicio de autenticación (Proceso)	✓	×	×	✓	✓	×
DB Usuarios (Almacén)	×	✓	×	✓	×	×
Microservicio de productos (Proceso)	×	×	×	✓	✓	×
DB Productos (Almacén)	×	✓	×	×	×	×
Microservicio de órdenes de compra (Proceso)	×	✓	×	✓	×	×
DB Órdenes de compra (Almacén)	×	✓	×	✓	×	×
Microservicio de pago (Proceso)	✓	✓	×	×	×	×
Backups protegidos (Almacén)	×	×	×	✓	✓	×

7.3 Justificación por elemento

7.3.1 Gestión de secretos (Almacén) – excluidos: S, T, R, E

- **S, E:** no aplican a almacenes (STRIDE-per-Element); la autenticación contra el vault y la asignación de privilegios se modelan en los procesos consumidores.
- **T:** los secretos se tratan como inmutables desde el consumidor; la rotación se administra mediante un proceso controlado del vault (**S9**) y los microservicios solo tienen permiso de lectura.
- **R:** la auditoría de accesos al vault se exporta al SIEM (**S8**); centralizar el no repudio aguas abajo evita duplicar el control.
- **Lo relevante aquí (I, D):** extracción de llaves privadas y caída del vault que detenga todas las operaciones que requieran credenciales.

7.3.2 Microservicio de autenticación (Proceso) – excluidos: T, R, E

- **T:** los hashes y tokens se generan y firman dentro del servicio con secretos aislados (**S9**) y HTTPS (**S1**); no hay puntos intermedios donde un atacante pueda alterar datos en este flujo de respaldo.
- **R:** eventos hacia el SIEM (**S8**); el control de no repudio se materializa en el destinatario de los logs.
- **E:** el servicio es el emisor de privilegios, no consumidor; la escalación solo es relevante en los servicios que consumen el token.
- **Lo relevante aquí (S, I, D):** suplantación entre servicios consumidores, fuga de credenciales y caída del servicio, que afectan la cadena de identidad de toda la plataforma.

7.3.3 DB Usuarios (Almacén) – excluidos: S, R, D, E

- **S, E:** no aplican a almacenes (STRIDE-per-Element).
- **R:** auditoría centralizada en el SIEM (**S8**).
- **D:** la DB está aislada de Internet (**S6**); la disponibilidad se modela en el microservicio consumidor.
- **Lo relevante aquí (T, I):** alteración o fuga de credenciales y datos personales del backup, lo más sensible del activo.

7.3.4 Microservicio de productos (Proceso) – excluidos: S, T, R, E

- **S:** no autentica al usuario final en consultas públicas del catálogo; entre servicios la autenticación se delega al microservicio de autenticación (**S2**).
- **T:** en este flujo opera principalmente como lector de secretos para conectarse a su DB; no hay datos en proceso susceptibles de manipulación significativa.
- **R:** eventos hacia el SIEM (**S8**).
- **E:** no expone endpoints administrativos en este flujo; las funciones privilegiadas viven en el Flujo 5.
- **Lo relevante aquí (I, D):** filtración accidental de configuraciones leídas del vault y caída por indisponibilidad del propio gestor de secretos.

7.3.5 DB Productos (Almacén) – excluidos: S, R, I, D, E

- **S, E:** no aplican a almacenes (STRIDE-per-Element).
- **R:** auditoría centralizada en el SIEM (S8).
- **I:** el catálogo es *público por definición* (precios, nombres, stock); no hay confidencialidad que comprometer en el activo.
- **D:** DB aislada (S6); la disponibilidad se modela en el microservicio consumidor.
- **Lo único relevante (T):** la integridad del catálogo respaldado, ya que una manipulación del backup distorsionaría toda la oferta comercial.

7.3.6 Microservicio de órdenes de compra (Proceso) – excluidos: S, R, D, E

- **S:** consume el JWT validado por upstream (S2); no autentica al usuario final.
- **R:** eventos al SIEM (S8) y la propia DB como registro autoritativo.
- **D:** mitigación perimetral en el API Gateway; el servicio se beneficia indirectamente.
- **E:** sin endpoints administrativos en este flujo (gestión administrativa en el Flujo 5).
- **Lo relevante aquí (T, I):** integridad y confidencialidad del backup transaccional, donde reside información financiera y personal.

7.3.7 DB Órdenes de compra (Almacén) – excluidos: S, R, D, E

- **S, E:** no aplican a almacenes.
- **R:** auditoría centralizada en el SIEM (S8); la DB actúa además como registro autoritativo.
- **D:** DB aislada (S6); la disponibilidad se modela en componentes upstream.
- **Lo relevante aquí (T, I):** igual que en DB Usuarios, lo que importa en el flujo de respaldo es preservar la integridad y la confidencialidad del histórico de órdenes.

7.3.8 Microservicio de pago (Proceso) – excluidos: R, I, D, E

- **R:** logs al SIEM (S8) más DB de órdenes como registro autoritativo.
- **I:** CompraFácil opera con *tokenización*, no almacena PAN ni CVV; los datos sensibles de tarjeta nunca residen en el microservicio (S10).
- **D:** mitigación perimetral en el API Gateway y cuotas del proveedor de pagos.
- **E:** sin roles diferenciados en este flujo; la administración financiera vive en el Flujo 5.
- **Lo relevante aquí (S, T):** verificar contra el banco con mTLS (suplantación del proveedor) y proteger la integridad de los payloads (monto, ID de orden, moneda) antes de firmar la transacción.

7.3.9 Backups protegidos (Almacén) – excluidos: S, T, R, E

- **S, E:** no aplican a almacenes (STRIDE-per-Element).
- **T:** configuración *WORM* (Write Once, Read Many) hace los respaldos inmutables por diseño; la alteración se neutraliza a nivel del producto. La amenaza remanente se reclasifica como pérdida de disponibilidad (borrado o cifrado por ransomware), que sí se modela como **D**.

- **R:** auditoría delegada al SIEM (**S8**); los backups no son fuente de evidencia transaccional sino copia de respaldo.
- **Lo relevante aquí (I, D):** fuga de los archivos físicos (si el cifrado en reposo falla) y borrado/inaccesibilidad de las copias, que son las dos preocupaciones centrales en cualquier estrategia de respaldo.

8. Lectura comparativa entre flujos

Las exclusiones varían entre flujos no porque la metodología cambie, sino porque la naturaleza de cada flujo desplaza la relevancia de cada categoría STRIDE:

- **Identidad (Spoofing):** central en el Flujo 1 (donde se emite la credencial del cliente) y en el Flujo 4 (donde el microservicio debe verificar que “el que responde es realmente el banco” vía mTLS). Marginal en el Flujo 2 (acceso anónimo), asumida validada upstream en el Flujo 3, y reforzada por MFA/SSO en el Flujo 5 (acceso administrativo).
- **Integridad (Tampering):** crítica en lecturas/escrituras con efecto financiero (Flujos 3 y 4), donde el monto y el estado del pago deben sobrevivir sin alteración. Se omite en lecturas públicas (catálogo) y, en el Flujo 6 (respaldo), se concentra en las bases de datos donde la copia debe preservar la fidelidad del original.
- **No repudio (Repudio):** se centraliza siempre en el SIEM (y, en flujos transaccionales, también en la DB de órdenes); no se modela en cada componente para evitar duplicidad. Aparece marcado especialmente en el Panel administrativo (Flujo 5), donde la trazabilidad del acto administrativo es central.
- **Confidencialidad (Information Disclosure):** crítica en datos personales y financieros; se descarta donde el activo es público por diseño (catálogo) o donde la tokenización del proveedor de pagos hace que el dato sensible nunca resida en el microservicio (Flujo 4). En el Flujo 6 vuelve a ser dominante porque los backups concentran información sensible histórica.
- **Disponibilidad (DoS):** se modela en el primer punto donde puede mitigarse (Gateway/microservicio); las bases de datos quedan protegidas por aislamiento. En el Flujo 6 se aplica especialmente al vault y a los backups, porque su caída detiene cobros y recuperaciones respectivamente.
- **Elevación de privilegios:** se modela en los componentes con *roles diferenciados*; se omite en los que carecen de lógica de autorización propia. Es la amenaza más característica del Flujo 5 (administración), donde la diferenciación entre roles administrativos es crítica.

9. Conclusiones generales

La exclusión de ciertos riesgos STRIDE en los DFD analizados **no implica que dichos riesgos hayan sido ignorados**, sino que:

- a) Se aplicó la heurística *STRIDE-per-Element*, evitando modelar amenazas que no aplican naturalmente al tipo de elemento.
- b) Se respetaron los **supuestos arquitectónicos (S1–S10)** del workshop, que delegan o centralizan ciertos controles en componentes específicos (SIEM para repudio, microservicio de autenticación para spoofing, vault para custodia de secretos, segmentación de red para DoS directo a bases de datos).
- c) Se reconoció la **naturaleza funcional** de cada flujo (autenticación, lectura pública, transacción), lo que define qué categorías son materialmente relevantes.

- d) Se evitó la **duplicidad analítica**: una amenaza modelada y mitigada en su componente natural no se repite en cada elemento adyacente.

Esta racionalización mantiene los modelos de amenazas coherentes con la arquitectura propuesta, fieles a la metodología STRIDE y útiles para la priorización de controles y la decisión sobre el riesgo residual de *CompraFácil S.A.S.*

Este documento cubre la totalidad de los seis flujos del modelo de amenazas del workshop: (1) Autenticación, (2) Consulta de catálogo, (3) Órdenes de compra, (4) Portal transaccional de pagos, (5) Gestión y operación administrativa, y (6) Respaldo y llaves de seguridad.